IS Audit & Control

Abdul-Rahman Mahmood
Assistant Professor, Computer Science, FAST-NU

abdulrahman@nu.edu.pk
alphapeeler.sf.net/pubkeys/pkey.htm
pk.linkedin.com/in/armahmood
bqb-tsid-asp
alphapeeler
alphapeeler
armahmood786
http://alphapeeler.sf.net/
reddit.com/user/alphapeeler
www.flickr.com/alphapeeler
http://alphapeeler.tumblr.com
armahmood786@jabber.org
alphapeeler@aim.com
abdulmahmood-sss
alphapeeler@icloud.com
pinterest.com/alphapeeler

Auditing Windows Operating Systems

Objectives

- A brief history of Windows development
- Windows essentials: learning about the target host
- How to audit Windows servers
- How to audit Windows clients
- Tools and resources for enhancing your Windows audits

Essential Command-Line Tools

- **UNIX compatibility tools** using Cygwin from ww.cygwin.com, which allows you to access several utilities such as ls, sed, grep, more, and cat.
- **Windows Resource Kit Tools**
  - more than 120 different tools for administering and troubleshooting systems, managing Active Directory, configuring security features, and much more.
- **Sysinternals Tools**, bought by Microsoft in 2006, help administrators and auditors perform complex tasks and detailed analysis. URL : www.sysinternals.com. Dozens of tools are available for remote administration, network analysis, process and registry monitoring, and other tasks.

Essential Command-Line Tools

- **Windows Forensic Toolchest (WFT),** written by Monty McDougal, serves as a wrapper for command-line tools. It can handle any of the tools listed here or others you may want to add. WFT is referenced as part of the SANS forensic track. You can learn more about it from www.foolmoon.net/security (and you might get a discount if you tell him you learned about it from this book).

Tool	Description	Where to Get It
psinfo	List system information, including installed service packs, patches, applications, and drive information	www.sysinternals.com
Systeminfo	List system information	Native command
Pslist	List running processes	www.sysinternals.com
psservice	List all installed services	www.sysinternals.com
cmdkey	Create, list, or delete stored credentials	Native command
Netsh	Display or modify network configuration	Native command
netstat	Provide network information	Native command
psservice	List service information	www.sysinternals.com
Sc	Tool for talking with service controller	Native command
DumpSec	GUI and command-line "Swiss army knife" of the security settings	http://somarsoft.com
tcpview	GUI view of processes mapped to ports	www.sysinternals.com
procexp	Powerful GUI process explorer	www.sysinternals.com
Fport	Command line view of processes mapped to ports	www.foundstone.com/knowledge/ proddesc/fport.html
schtasks	List scheduled tasks at the command line	Native command
bootcfg	List boot partition information	Native command
pendmoves	List file move operations scheduled for the next reboot	www.sysinternals.com
autoruns	List everything scheduled to start when your computer starts up—the GUI version	www.sysinternals.com
autorunsc	List everything scheduled to start when your computer starts up—the command-line version.	www.sysinternals.com
rsop.msc	Open the resulting set of security policies on your host when run from the Start | Run box or command line	Native command
secpol.msc	Open just the local computer policy	Native command
Pwdump	Dump Windows password hashes into a format usable by nearly all free and commercial password crackers	http://openwall.com/passwords

Steps for Auditing Windows

- 1. Obtain the system information and service pack version and compare with policy requirements.
  - Sysinternals tool **psinfo** and the native tool **systeminfo**. Go to sysinternals.com and download the pstool package.
- 2. Determine whether the server is running the company-provisioned firewall.
  - by running **pslist <process name>,** and search for the appropriate running process.
  - If you are using the Windows Firewall, run: **netsh firewall show config** to see the overall configuration of the firewall on the host and whether the firewall is configured for particular adapters.

Steps for Auditing Windows

- 3. Determine whether the server is running a company-provisioned antivirus program.

```
pslist MsMpEng
PsList 1.4 - Process information lister
Copyright (C) 2000-2016 Mark Russinovich
Sysinternals - www.sysinternals.com
Process information for MK-PROD:
Name Pid Pri Thd Hnd Priv CPU Time Elapsed Time
MsMpEng 10012 8 30 981 416528 0:53:58.843 437:26:12.997
```

- 4. Ensure that all approved patches are installed per your server management policy.
  - Use **systeminfo or psinfo -s** to pull this information up for you, and then compare the results against the policies and requirements of your organization.
  - You can use the output to compare with existing SMS/SCCM, patchlink, and other patch-management data.

Steps for Auditing Windows

- 5. Determine whether the server is running a company-provisioned patch-management solution.
  - Existence of the process (e.g., CcmExec.exe) in the Task Manager or the output of pslist.
  - Enable automatic updates, by looking for "Automatic Updates" in the Control Panel.
  - Verify whether the system shows up on the Microsoft System Center Configuration Manager (SCCM) console and validate last patch cycle applied to a given machine.
- 6. Review and verify startup information.
  - Several utilities can help you dissect what the next reboot will do to the system.
  - E.g., **pendmoves**, and **autoruns**.

Steps for Auditing Windows

- 7. Determine what services are enabled on the system, and validate their necessity with the system administrator. For necessary services, review and evaluate procedures for assessing vulnerabilities associated with those services and keeping them patched.

Tool	Description	Where to Get It
Netstat	Provide network information	Native Windows command
Psservice	List service information	www.sysinternals.com
Sc	Native tool for talking with service controller	Native Windows command
DumpSec	GUI and command-line "Swiss army knife" of the security settings	www.somarsoft.com
Tcpvcon	CLI view of processes mapped to ports	www.sysinternals.com
Tcpview	GUI view of processes mapped to ports	www.sysinternals.com
Procexp	Powerful GUI process explorer	www.sysinternals.com

Tools for Viewing Service Information

Steps for Auditing Windows

- 8. Ensure that only approved applications are installed on the system per your server management policy.
  - Use the results from the output of psinfo –s, which includes information about the installed applications.
- 9. Ensure that only approved scheduled tasks are running.
  - you can view tasks from the command line using **schtasks**:

```
The current directory is C:\>
schtasks
TaskName            Next Run Time          Status
========            ====================   ==========
Malicious Task      12:27:00 PM,           6/13/2011
```

Steps for Auditing Windows

- 10. Review and evaluate procedures for creating user accounts and ensuring that accounts are created only for a legitimate business need. Review and evaluate processes for ensuring that accounts are removed or disabled in a timely fashion in the event of termination or job change.
- 11. Ensure that all users are created at the domain level and clearly annotated in the active directory. Each user should trace to a specific employee or team.
  - You can view the accounts by opening compmgmt.msc from the command line or with a tool such as DumpSec using the following syntax:

```
Dumpsec /rpt=dir=c:\ /saveas=csv /outfile=c:\temp\dirC.txt
DumpSec.exe /rpt=users /saveas=fixed /outfile=users.txt
```

Steps for Auditing Windows

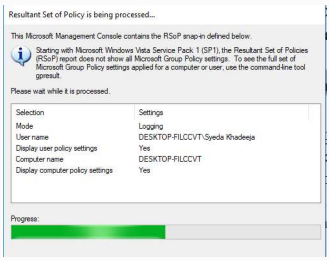
- 12. Review and evaluate the use of groups, and determine the restrictiveness of their use.
  - Active Directory groups can be nested, and you need to check the membership of the nested groups.
  - Investigate the use of shared accounts.
- 13. Review the strength of system passwords.
  - test Windows password hashes by using pwdump (commonly used tool to dump password hashes from systems). URL: http://openwall.com/passwords

Cracker	Cost	Comments
John	Free	www.openwall.com. A fast brute-force cracker that supports dictionaries and is accessed from the command line.
Rcrack	Free	Code is originally from Zhu Shuanglei at www.antsight.com/zsl/rainbowcrack. Built into a lot of tools such as Cain and Abel (www.oxid.it). You must find, generate, or buy tables.
Ophcrack	Free	Sometimes buggy, but free and quick. Comes with rainbow tables; download at http://ophcrack.sourceforge.net.

Common Password Crackers

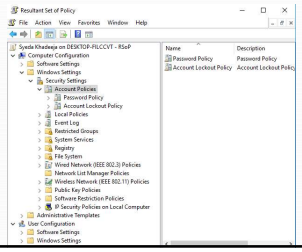
Steps for Auditing Windows

- 14. Evaluate the use of password controls on the server, such as password aging, length, complexity, history, and lockout policies.
  - Find account policies by typing **rsop.msc** at the command line.



Steps for Auditing Windows

- 14. Evaluate the use of password controls on the server, such as password aging, length, complexity, history, and lockout policies.
  - When the window opens, choose Computer Configuration | Windows Settings | Security Settings | Account Policies. In general, verify that the policies listed in flowing Table are set in accordance with your local policies. Some common settings are listed.



Steps for Auditing Windows

Policy	Setting
Minimum password age	1 day
Maximum password age	90–180 days
Minimum password length	8 characters
Password complexity	Enabled
Password history	10–20 passwords remembered
Store passwords using reversible encryption	Disabled, if possible, but understand and test this before making this decision
Account lockout duration	10–30 minutes
Account lockout threshold	10–20 attempts
Reset account lockout after	10–30 minutes

Account Policies

Steps for Auditing Windows

- **15. Review and evaluate the use of user rights and security options assigned to the elements in the security policy settings.**
  - Type rsop.msc or secpol.msc at command line.
  - After the GUI opens, choose Computer Configuration | Windows Settings | Security Settings | Local Policies.
  - Export settings by right-clicking the folder icon and selecting Export List.
  - Another helpful command-line option is to type **.gpresult** to get a summary of group policy settings.

Steps for Auditing Windows

- Common security options include the following:
  - Renaming guest and administrator accounts
  - Disabling the guest account
  - Choosing not to display the last logged on user
  - Prompting user to change password before expiration
  - Refusing enumeration of SAM accounts and shares by anonymous.
  - Refusing to store network credentials (careful with this)
  - Changing local-area network (LAN) manager responses
- Common user rights assignments include the following:
  - Changing who can access the computer across the network
  - Defining who can log on locally
  - Denying access to the computer from the network
  - Denying logon through terminal services
  - Defining who can take ownership of file or other objects

Steps for Auditing Windows

- Refusing enumeration of SAM accounts
  - Configure the policy value for Computer Configuration >> Windows Settings >> Security Settings >> Local Policies >> Security Options >> "Network access: Do not allow anonymous enumeration of SAM accounts" to "Enabled".
  - https://learn.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/network-access-do-not-allow-anonymous-enumeration-of-sam-accounts-and-shares
- Changing local-area network (LAN) manager responses
  - Configure the **Network** security: **LAN Manager** Authentication Level setting to Send NTLMv2 **responses** only
  - https://learn.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/network-security-lan-manager-authentication-level

Steps for Auditing Windows

- **16. Review and evaluate the use and need for remote access, including RAS connections, FTP, Telnet, SSH, VPN, and other methods.**
  - Question the need for any **clear-text** communications.
  - An encrypted protocol should be used instead. For Microsoft hosts, **encrypted protocols** include the Remote Desktop Protocol (RDP), Citrix (ICA protocol), Secure Shell (SSH), and Secure Sockets Layer (SSL), among many others.
  - On a Windows server, you can find information about remote access by choosing Start | Administrative Tools | Routing and Remote Access.

Steps for Auditing Windows

- **17. Ensure that a legal warning banner is displayed when connecting to the system.**
- **18. Look & evaluate the use of shares on the host.**
  - Type compmgmt.msc command. When the MMC opens, go to Computer Management | System Tools | Shared Folders to view open shares, sessions, and files.
  - List of shares:
    `DumpSec.exe /rpt=shares /saveas=fixed /outfile=TempFile01`
  - List of directories:
    `DumpSec.exe /rpt=allsharedirs /saveas=fixed /outfile=TempFile02`
  - view list of shares by "**net share**". You can
  - view remotely opened files by running **psfile** from Sysinternals or use the command **net file**.

Steps for Auditing Windows

- **19. Ensure that the server has auditing enabled per your organization's policies.**
  - You should view your audit settings manually with the MMC Group Policy snap-in.
  - `DumpSec.exe /rpt=policy /saveas=fixed /outfile=policies.txt`
- **20. Review and evaluate system administrator procedures for monitoring the state of security on the system.**
  - Interview the system administrator and review any relevant documentation to get an understanding of security monitoring practices.
  - a web server in the DMZ should have more robust security monitoring than a print server on the internal network

Simplified Audit of Windows Client

- **1. Determine whether the client is running the company-provisioned firewall.**
- **2. Determine whether the client is running a company-provisioned antivirus program.**
- **3. Determine whether the client is running a company-provisioned patch-management solution.**
- **4. Determine whether the client is equipped with the minimum recommended service pack, hotfixes, and software.**
  - pstools, psinfo

Simplified Audit of Windows Client

```
The current directory is C:\PERL>
psinfo
PsInfo v1.73 - Local and remote system information viewer
Copyright (C) 2001-2005 Mark Russinovich
SysInternals - www.SysInternals.com
System information for \\CA-CDAVIS:
Uptime:     0 days 10 hours 42 minutes 25 seconds
Kernel version:   Microsoft Windows XP, Multiprocessor Free
Product type:     Professional
Product version:        5.1
Service pack:     2
Kernel build number:    2600
Registered organization:
Registered owner:       Christopher Davis
Install date:     4/19/2006, 1:57:31 PM
IE version:       6.0000
```

Simplified Audit of Windows Client

- **5. Ensure that the client has all the following according to the Microsoft Baseline Security Analyzer (MBSA).**
  - MBSA will check for this and many other common mistakes, such as the following:
  - Active accounts with blank or weak passwords
  - Using file systems older than NTFS
  - Autologin enabled
  - Guest accounts enabled
  - Anonymous access
  - Logon auditing
  - IIS enabled

Simplified Audit of Windows Client

- **6. Scan the system using a commercial-grade network scanner.**
  - Nessus scanner (free) https://www.tenable.com/products/nessus
- **7. Evaluate physical security controls during a walk-through.**
  - Cable locks should be used on laptops.
  - Users should be logged out of their workstations.
  - Passwords should not be written down anywhere.



Tools and Technology

Resource	Website
Microsoft Script Center	www.microsoft.com/technet/scriptcenter/default.mspx
Microsoft Command-line Reference	http://technet.microsoft.com/en-us/library/cc754340(WS.10).aspx
Microsoft Sysinternals Tools	http://www.sysinternals.com (Redirects to Microsoft Technet)

Tools and Technology: Auditing Windows

Knowledge Base

Resource	Website
Microsoft Server and Tools	www.microsoft.com/servers/home.mspx
Microsoft TechNet	www.technet.com
Microsoft System Center	www.microsoft.com/systemcenter
Windows Intune	www.microsoft.com/online/windows-intune.aspx
Microsoft Tech-Ed Online	www.msteched.com
Windows Products	www.microsoft.com/windows/products
TCP/IP Fundamentals for Windows	http://technet.microsoft.com/en-us/library/cc307741.aspx
Secure Windows Server	http://technet.microsoft.com/en-us/library/dd548350(WS.10).aspx
Windows Firewall with Advanced Security	http://technet.microsoft.com/en-us/library/dd772715(WS.10).aspx
Microsoft Security Assessment Tool	http://technet.microsoft.com/en-us/security/cc185712.aspx
Microsoft Baseline Security Analyzer	http://technet.microsoft.com/en-us/security/cc184924.aspx
The Center for Information Security	www.cisecurity.org
Computer Security Resource Center	http://csrc.nist.gov
KeePass Password Tool	http://keepass.sourceforge.net